

---

SESIÓN 2

# Adquisición y Preservación de Evidencia Digital

**Mg. Edwin Moreyra Hernández**

ESAN Business

## 01 Marco Normativo y Principios

ISO 27037 y reglas de evidencia admisible

## 02 Procedimientos de Adquisición

Como adquirir correctamente

## 03 Dinámica de Aplicación

Casos prácticos y escenarios militares

Define las bases para que la evidencia digital sea admisible ante cualquier tribunal o mando superior.

## DEFR

*Digital Evidence First Responder*

- Primer contacto con la escena
- Asegura y protege los dispositivos
- Documenta el estado inicial

## DES

*Digital Evidence Specialist*

- Realiza la adquisición compleja
- Análisis técnico especializado
- Valida la integridad de la evidencia

*La norma distingue claramente entre ambos roles para garantizar la especialización en cada etapa.*



*En entornos operacionales, el equilibrio entre urgencia y preservación es crítico.*

## Acta de Adquisición

*(El Acto Técnico)*

- Documenta el proceso realizado
- Herramientas usadas paso a paso
- Resultados técnicos (Hashes)
- Campos: Herramienta, hash, ejecutor, fecha/hora

## Cadena de Custodia

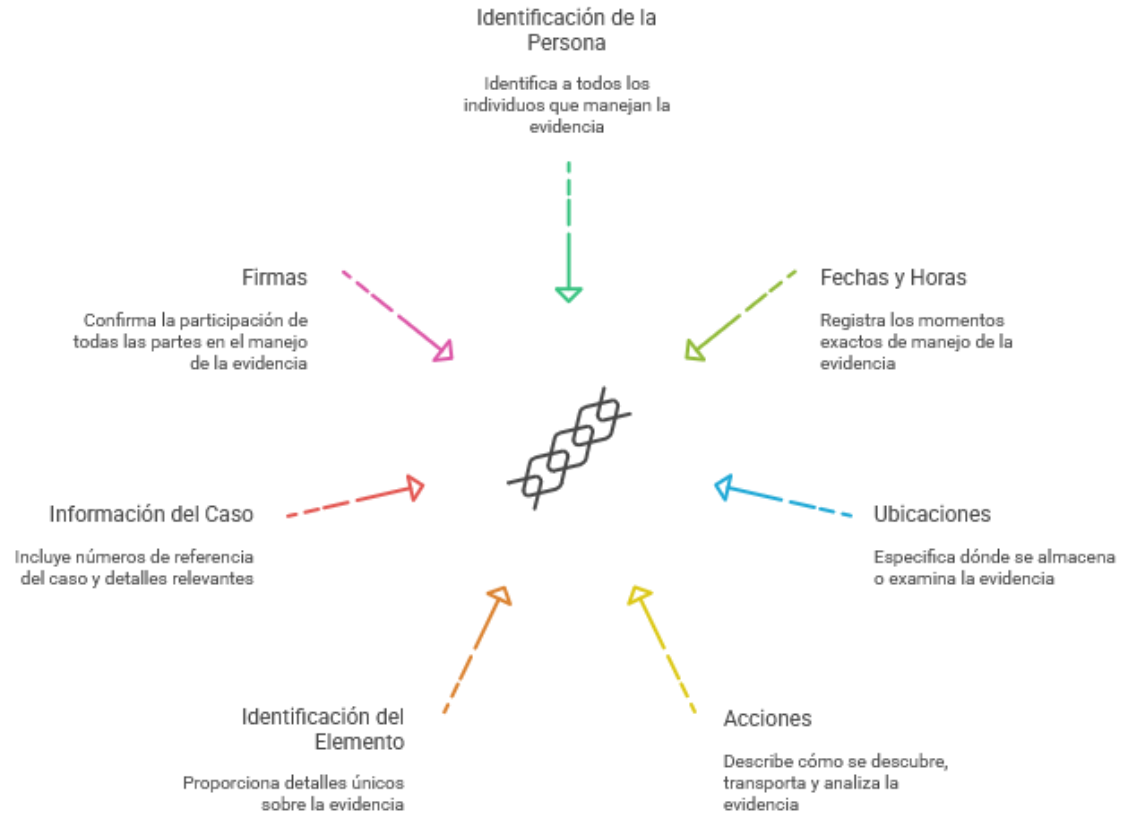
*(La Trayectoria)*

- Documenta la vida del dispositivo
- Quien lo tuvo y cuando se transfirió
- Estado físico en cada transferencia

El Acta registra como se hizo la copia; la Cadena registra quien tuvo el original y en qué condiciones.

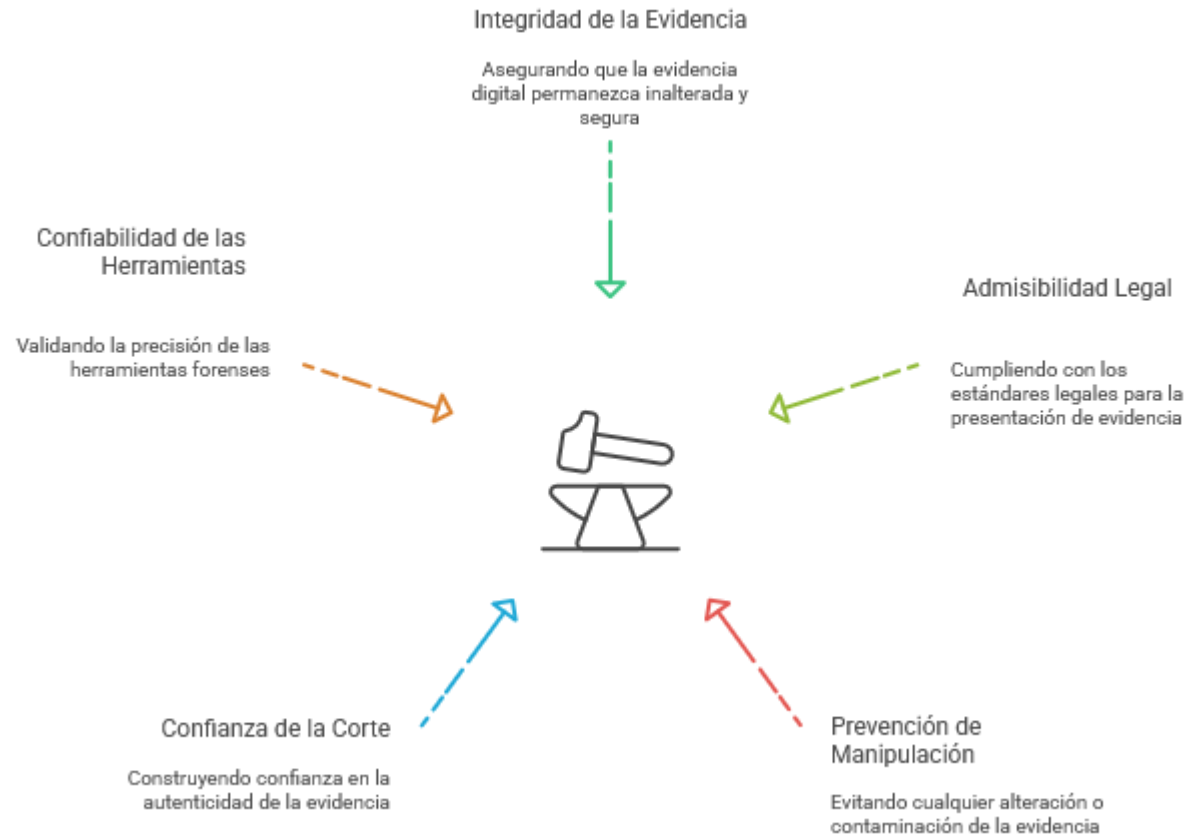
# Componentes de la Cadena de Custodia

Documento que garantiza que la evidencia analizada es la misma que se incautó



# Importancia de la Cadena de Custodia

Documento que garantiza que la evidencia analizada es la misma que se incauto



**Una cadena de custodia mal llenada puede causar la inadmisibilidad legal de la prueba.**

## Adquisición Física

*(Bit-a-bit)*

- Copia cada sector del disco
- Incluye espacio "vacío" con archivos borrados
- Formatos: .E01
- Compresión y metadatos internos
- Máxima recuperación de datos

## Adquisición Lógica

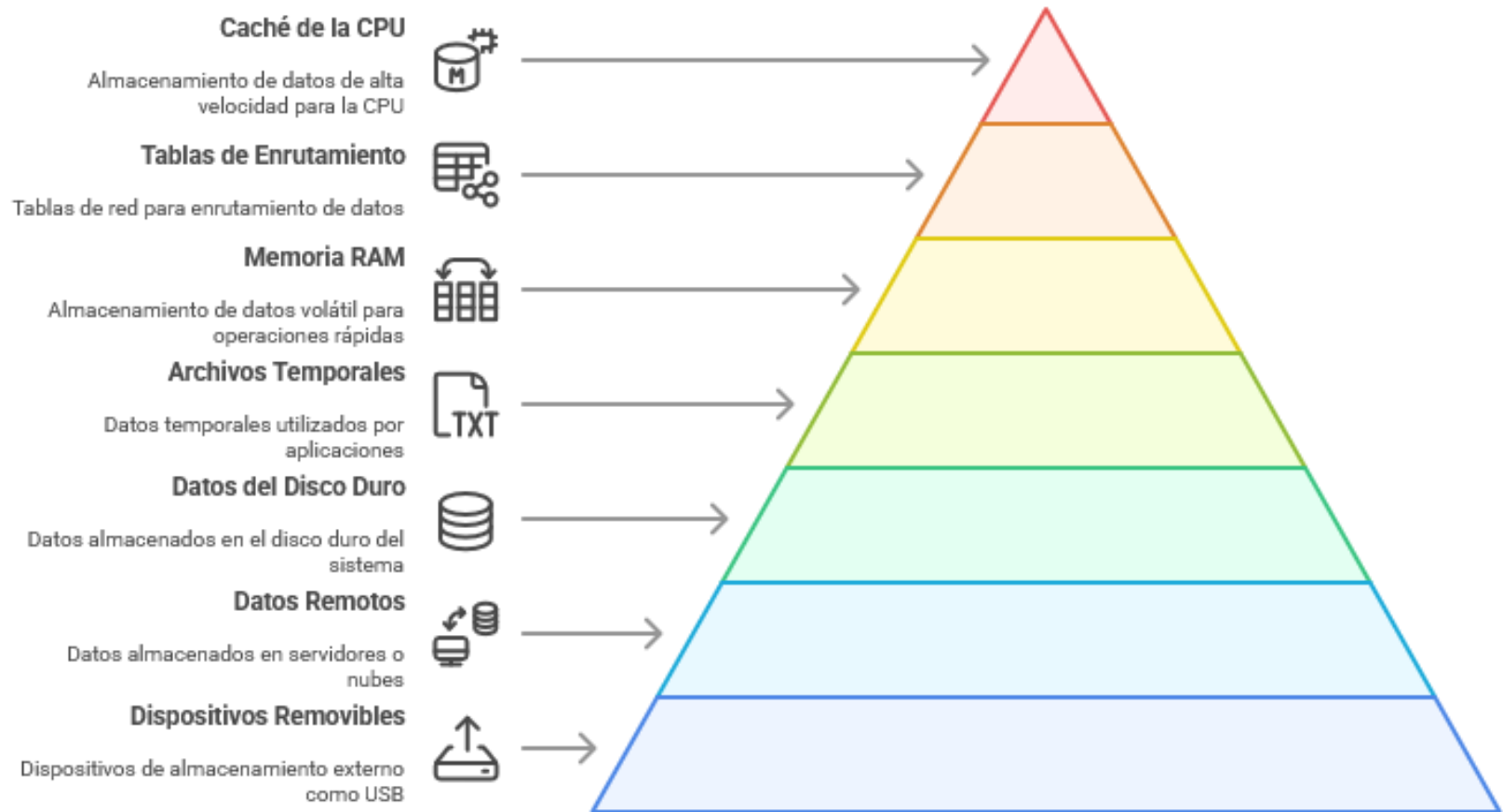
*(Archivos visibles)*

- Solo extrae archivos visibles
- Más rápida que la física
- No recupera datos eliminados
- Útil cuando el tiempo es limitado
- Menor valor probatorio

La norma exige elegir el mejor método disponible y justificar la decisión. La física captura todo; la lógica aplica cuando el tamaño, la operatividad o las circunstancias del caso lo requieren.



# Orden de Volatilidad e Integridad



*Lo más arriba desaparece primero. Capturar en ese orden.*

## Hardware de Adquisición



Duplicador Tableau



Talon Ultimate

## Software

### Adquisición de Disco

- FTK Imager
- dd
- dc3dd
- Guymager

---

### Captura de RAM

- DumpIt
- Magnet RAM Capture

01

## Identificación

Etiquetado físico del dispositivo con código único y registro en la cadena de custodia.

02

## Protección de Escritura

Uso de bloqueadores hardware para impedir que el SO escriba datos en el disco original.

03

## Captura de Imagen

Ejecución de la imagen forense completa del disco o medio de almacenamiento.

04

## Validación (Hash)

Cálculo inmediato del Hash para verificar integridad de la copia.

Cada paso debe quedar documentado: herramienta usada, decisiones tomadas, cambios realizados y su justificación — ISO/IEC 27037, Cláusula 6.6

# Recolección de evidencias



# Caso 1: Copia con Windows

El técnico que copió los archivos sin herramientas forenses

## ESCENARIO

El oficial de TI Ramírez recibe el disco duro de un equipo incautado en una oficina administrativa. Le piden extraer toda la información posible lo antes posible.

Ramírez conecta el disco directamente a su computadora Windows, abre el Explorador de archivos, selecciona todas las carpetas y las arrastra a una carpeta en su equipo. El proceso tarda 20 minutos. Al terminar anota: "Copia completada. 47 GB copiados."

Tres días después, cuando el caso llega al área jurídica, preguntan: ¿cómo verificamos que esta copia es idéntica al original? ¿Qué proceso se siguió? Nadie tiene respuesta.

### Aciertos

#### PARCIALES

- Entendió la necesidad de preservar
- Documentó el peso total de los datos

### Errores Críticos

#### GRAVES

- Sin Write-blocker: SO modificó metadatos
- Copiar con el Explorador de Windows no es adquisición forense
- Sin cálculo de Hash

*Concepto Clave: La adquisición forense requiere integridad técnica (Hash) e integridad de datos (imagen bit-a-bit).*

## Caso 2: Custodia sin Firmas

El formulario de custodia que nadie firmo

### ESCENARIO

Durante una auditoría de seguridad en la oficina de recursos humanos, se detecta que un equipo de escritorio tuvo accesos no autorizados a la base de datos de personal. El equipo es incautado un miércoles a las 09:15 por el Subteniente Flores, quien lo lleva al área de TI.

El técnico Mendoza recibe el equipo, genera correctamente una imagen forense con FTK Imager, calcula el hash y lo archiva. Sin embargo, nadie llenó ningún formulario de cadena de custodia. El equipo pasó por cuatro manos entre incautación y análisis sin ningún registro escrito.

Dos semanas después, cuando el caso llega a instancia disciplinaria, el abogado de la defensa argumenta que no puede verificarse quién tuvo acceso al equipo ni en qué condición estaba cuando llegó al laboratorio.

### Aciertos

#### TECNICA CORRECTA

- Uso de herramienta forense (FTK Imager)
- Cálculo correcto de hash
- Imagen forense completa generada

### Errores Críticos

#### FATALES

- Ruptura de trazabilidad total
- Evidencia inadmisible legalmente

*Concepto Clave: El Hash garantiza que la copia es igual al original; la cadena de custodia garantiza que el original es el que se incautó.*

## Caso 3: Ataque Activo

¿Que debe hacer el técnico Torres?

### ESCENARIO

En la oficina de planificación se detecta que el equipo del Capitán Vega está siendo controlado remotamente en ese momento. El equipo está encendido, con sesión activa y conexiones de red en curso. Se sospecha que el atacante aún tiene acceso.

El técnico Torres llega a la escena y debe actuar de inmediato. Tiene disponible: una unidad USB con herramientas forenses (DumpIt para RAM), su laptop con FTK Imager, y un write-blocker.

Hay un debate urgente: ¿Desconecto primero la red para cortar al atacante? ¿Capturo la RAM antes? ¿O apago el equipo y después hago la imagen del disco?

**Opción A — Apagar el equipo primero**

**Opción B — No tocar nada y esperar instrucciones**

**Opción C — Desconectar red → capturar RAM → imagen de disco**

**Opción D — Imagen de disco primero, sin capturar RAM**

**Opción A — Apagar el equipo primero:** Error crítico. Al apagar se pierde toda la RAM: claves de cifrado, proceso del atacante en memoria, conexiones activas. Exactamente la evidencia más valiosa de un ataque en curso.

**Opción B — No tocar nada y esperar instrucciones:** Discutir con el grupo. En un ataque en curso cada segundo importa — pero actuar sin protocolo puede ser peor. ¿Cuándo está justificado esperar?

**Opción C — Desconectar red → capturar RAM → imagen de disco:** Correcto. Cortar la red detiene al atacante sin perder la evidencia volátil. La RAM contiene las claves de cifrado activas, el proceso malicioso y las conexiones establecidas. Luego la imagen de disco con hash.

**Opción D — Imagen de disco primero, sin capturar RAM:** Error. El disco puede esperar — su contenido es no volátil. La RAM se pierde en cuanto el equipo se apague o el atacante cierre sus procesos. Invertir el orden destruye la evidencia más crítica.

*Concepto Clave: El orden de volatilidad (RFC 3227) dicta que la RAM siempre va antes que el disco duro.*



## Analizar el Original

Nunca se debe trabajar sobre el disco incautado. Siempre sobre la copia forense.

***Consecuencia: Contaminación irreversible de la evidencia***

## Omitir el Hash

Sin verificación de integridad, no hay garantía de que la evidencia sea auténtica.

***Consecuencia: Inadmisibilidad de la prueba***

## Usar Herramientas No Forenses

Copiar archivos con métodos comunes (ej. copiar/pegar) altera las fechas de acceso y creación.

***Consecuencia: Destrucción de metadatos valiosos***

# Resumen de la Sesión

---

## SÍ:

- Seguir la ISO 27037 como marco de actuación.
- Documentar todo: acta de adquisición + cadena de custodia firmada.
- Usar herramientas forenses y calcular Hash en cada copia.
- Respetar el orden de volatilidad: RAM antes que disco.

## NO:

- Analizar sobre el original — siempre trabajar sobre la copia forense.
- Apagar equipos sin capturar primero la memoria volátil.
- Copiar archivos con métodos comunes (Explorador, copiar/pegar).
- Romper la cadena de custodia — sin firmas no hay prueba válida.